

Sentinel Stacks Brain - Beginner's Build Report (B1 -> B3)

Product: Sentinel Stacks

Layer: Brain (shared multi-role AI agent / orchestrator)

Tool ID: orchestrate_role_brain

Main files: ai_brain_agent.py, ai_brain_llm.py

Final version: 0.3.0-b3

Status: Brain agent spine COMPLETE for this phase (orchestrate + watch + LLM brief + manager approval)

Lab repo: ibkbalo/secops-pipeline-lab

Report date: 2026-08-05

Commit on main: 219912e (B1-B3 shipped together)

1. Start here - what is the Brain?

Imagine you hired four security specialists:

- * Security Engineer
- * DevSecOps
- * Cloud Security Engineer
- * AI Security Engineer

Those specialists are the Hands (already built).

The Brain is the manager-facing workforce layer that:

1. Runs all four Hands
2. Drafts fix kits (hardening kits)
3. Explains / prioritizes work (LLM or offline brief)
4. Queues jobs for human approval
5. Never silently changes production

Plain English	Technical name
Four specialist scanners	Role Hands packs
The always-on coordinator	Brain (ai_brain_agent.py)
The thinking / briefing step	LLM node (ai_brain_llm.py)
Your yes/no decision	Manager approval gate
Proposed fix pack	Hardening kit ZIP (dry-run)
Tomorrow's console	Face (GUI - not built yet)

Product promise: customers rent an autonomous security workforce; you (or your managers) approve the work. Data stays local.

2. Why Brain exists (product story)

2.1 Hands alone are not enough

Hands can find hundreds of issues and generate kits. Without Brain:

- * Someone must run each pack manually
- * There is no shared inbox
- * There is no 24/7 loop
- * There is no CEO/manager brief

Brain turns four tools into one workforce agent.

2.2 Design rules locked for enterprise trust

Rule	Meaning
One Brain, four Hands	Not four separate brains
Manager approval required	Approve/reject before any future app
Auto-apply forbidden	Kits are drafts; no silent cloud/rep
Customer-local data plane	State in brain_workspace/; keys stay
Evidence-bound reasoning	Briefs must reference real job/findi
Offline fallback	Works without OpenAI/Anthropic for I

2.3 Hands -> Brain -> Face

Hands (done)	scan + FIX_MAP kits
Brain (this report)	orchestrate + watch + LLM brief + approve
Face (next)	manager GUI + founder reports

3. What the Brain controls

3.1 The four role workers

Role key	Title	Hands module	Finding IDs
security-engineer	Security Engineer	ai_security_engineer_pack.py	PERIM-*
devsecops	DevSecOps	ai_devsecops_pack.py	DEVSEC-*
cloud	Cloud Security Engineer	ai_cloud_pack.py	CLOUD-*
ai-security	AI Security Engineer	ai_ai_security_pack.py	AISEC-*

Mock cycle totals (vulnerable fixtures): $53 + 62 + 170 + 43 = 328$ findings.

3.2 Remediation kits (what you approve)

After each role scan with findings, Brain calls ai_remediation_engine.py in dry_run mode.

Each kit typically contains:

Piece	Purpose
runbooks/*.yaml	Step-by-step manual fix guide
configs/*	Config snippets
terraform/*	Infra templates when relevant

README.md	How to use the kit
manifest.json	Machine index of generated items

If you never auto-apply, a human can still fix issues by following the kit.

3.3 Local workspace (data plane)

```
brain_workspace/
  cycles/      one JSON per Brain cycle
  jobs/        pending / approved / rejected jobs
  scans/       raw Hands scan reports
  briefs/      LLM or offline briefs
  audit.jsonl  manager + cycle audit trail
  index.json   pending/approved/rejected lists
  watch_state.json
```

This folder is gitignored. Customer data stays on their machine/VPC.

4. How it fits together (architecture)

```
Manager starts Brain (cycle or watch)
      |
      v
  ai_brain_agent.py
      |
  +-----+-----+
  |         |         |
  v         v         v
Hands x4   Remediation  LLM node
(packs)   (dry-run kits) (brief/reason)
  |         |         |
  +-----+-----+
      v
Pending jobs (inbox)
      |
      v
Manager approve / reject
      |
      v
Audit log (who decided what)
      |
      v
Apply later (NOT in B3 - reserved)
```

Key files:

File	Purpose
ai_brain_agent.py	Orchestrator, watch, jobs, approval
ai_brain_llm.py	OpenAI / Anthropic / offline reasoni
ai_remediation_engine.py	Hardening kit generator

tool_registry.json	Catalog entry orchestrate_role_brain
Four ai_*_pack.py modules	Hands workers

5. Phase-by-phase - what we built

Brain was delivered in 3 phases (B1 -> B3). Unlike Hands (many engine activations), Brain is one product layer finished in a short sequence.

5.1 Rollup table

Phase	Version	What turned on	Manager meaning
B1	0.1.0-b1	Shared cycle across 4 roles, kit dra	First inbox
B2	0.2.0-b2	Watch loop, job dedupe, audit log	24/7 floor pattern
B3	0.3.0-b3	LLM brief/reason (OpenAI/Anthropic)	Real AI judgment node

Note: B1 and B2 were developed locally first; B1-B3 were committed/pushed together as 219912e.

5.2 B1 - Shared orchestrator + approval gate

Goal: One Brain for all four Hands.

- * Registry-backed role workers
- * cycle runs selected roles (default: all four)
- * Drafts dry-run kits via remediation engine
- * Creates pending_approval jobs
- * approve / reject record manager decision only
- * Apply explicitly not executed

5.3 B2 - Always-on watch + dedupe + audit

Goal: Production-floor pattern without babysitting every cycle.

- * watch / serve: cycle -> sleep -> cycle (Ctrl+C to stop)
- * Dedupe: same open finding fingerprint does not spam new jobs
- * audit.jsonl: cycle start/stop, manager decisions
- * Status dashboard counts: pending / approved / rejected

Example watch proof:

```
cycle #1: findings=43 new_jobs=1 deduped=0
cycle #2: findings=43 new_jobs=0 deduped=1
```

5.4 B3 - LLM reasoning node

Goal: Not just automation - an AI agent that briefs the manager.

- * Module: ai_brain_llm.py
- * Providers: OpenAI, Anthropic, offline heuristic
- * Actions: brief, reason

- * Optional --llm on cycle / watch / pending
 - * Structured output: executive summary, CEO brief, priority actions
 - * Forced: requires_manager_approval=true, auto_apply=false
 - * If OpenAI fails or key missing -> safe offline fallback
-

6. Try it yourself (copy-paste)

Run from repo root. Windows PowerShell examples.

6.1 Status

```
cd C:\DevSecOps-Lab\secops-pipeline-lab
python ai_brain_agent.py status
```

6.2 One mock cycle (all four roles)

```
python ai_brain_agent.py cycle --mock
```

Expect about 328 findings and up to 4 new jobs (or fewer if deduped).

6.3 AI Security only + offline brief (no API key)

```
python ai_brain_agent.py cycle --mock --roles ai-security --llm --provider offline
python ai_brain_agent.py brief --provider offline
```

6.4 Manager inbox

```
python ai_brain_agent.py pending
```

Copy a real job id (do not type the words JOB_ID_HERE):

```
python ai_brain_agent.py approve job_20260805T162646Z_2fbf96d7
python ai_brain_agent.py reject job_20260805T162649Z_38ac3ecf
```

6.5 Always-on watch (lab)

```
python ai_brain_agent.py watch --mock --interval 300 --llm
```

Stop with Ctrl+C. Interval 300 = 5 minutes between cycles.

6.6 Optional live OpenAI brief

Key must be set before the command, in the same terminal:

```
$env:OPENAI_API_KEY = "sk-your-real-key"
python ai_brain_agent.py brief --provider openai
```

Success looks like:

```
Provider: openai (gpt-4o-mini)
```

If you see [Fallback after openai error] and Provider: offline, the key was missing, invalid, or set after the command.

Session tip: \$env:... lasts for that PowerShell window only. Production will store the key once per environment (not paste every brief).

6.7 Audit trail

```
python ai_brain_agent.py audit
```

Look for events like cycle_completed, llm_brief, manager_approve, watch_started.

6.8 Review a proposed kit before approve

From pending, open the kit=... ZIP path, or:

```
explorer hardening_kits
```

7. How to read Brain output (novice / CTO / CISO)

Example cycle line

```
findings_total=328 jobs_new=4 jobs_deduped=0
```

Field	Meaning
findings_total	Issues found this cycle across selec
jobs_new	New approval requests created
jobs_deduped	Same open work refreshed, not duplic

Example role line

```
[ai-security] findings=43 kit_mapped=43 approval_needed=True
```

Field	Meaning
findings=43	Hands found 43 issues
kit_mapped=43	All 43 have FIX_MAP templates
approval_needed=True	Waiting on manager

Approve success

```
approve ok: job_... status=approved
Manager approved the proposed kit. ... Apply ... not executed ...
```

Meaning: plan accepted; still no automatic production change in B3.

One-sentence CISO pitch

Sentinel Stacks Brain runs four security specialist agents, drafts fix kits, briefs leadership with optional LLM judgment, and waits for a human manager - no silent changes, data stays local.

8. LLM key model (simple)

Situation	Need OpenAI key?
Lab offline demo	No
Offline brief	No
Live OpenAI/Anthropic brief	Yes
Production deploy (later)	Configure once per environment

Customers later bring their key inside their VPC. You do not need their data in your cloud for Brain to work.

9. What is NOT in this Brain report (honest gaps)

B3 is a strong agent spine, not full Fortune-500 production by itself.

Gap	Planned later
Face GUI	Next
Auth / SSO / RBAC	After Face
Multi-tenant client A/B	After Face
Controlled apply after approve	After trust layer
Docker / service / K8s install	Deploy pack
Slack/email/PagerDuty alerts	Ops phase
SLA / metrics dashboards	Ops phase

These are on the enterprise ladder - not forgotten.

10. What comes next

Step	Status	Plain English
Hands (4 roles)	Done	Specialists exist
Brain B1-B3	Done	Workforce agent + LLM brief + approv
Face	Next	Manager console / click to review &
Auth + tenants	Planned	Your managers vs customer managers
Controlled apply	Planned	After approve, act in their environm
Deploy pack	Planned	VPC / Docker one-time install

11. One-page cheat sheet

```

Product ..... Sentinel Stacks Shared Role Brain
Modules ..... ai_brain_agent.py + ai_brain_llm.py
Version ..... 0.3.0-b3
Tool ID ..... orchestrate_role_brain
Roles ..... security-engineer, devsecops, cloud, ai-security
Mock findings/cycle .. ~328 (all four)
Watch ..... yes (interval + Ctrl+C)
Dedupe ..... yes
LLM ..... openai | anthropic | offline
Approval ..... required
Auto-apply ..... forbidden
Data plane ..... brain_workspace/ (local)
Kits ..... hardening_kits/ (dry-run ZIPs + runbooks)
Commit ..... 219912e on origin/main
Next ..... Face (manager GUI)

```

12. Glossary for beginners

Term	Simple definition
Hands	The four role scanner packs
Brain	Shared agent that runs Hands, briefs
Face	Future GUI for managers
Job	One approval package (usually one ro
Hardening kit	ZIP of proposed fixes and step-by-st
Dry-run	Generate fixes without applying them
Watch	Always-on loop: scan, sleep, repeat
Dedupe	Do not create duplicate pending jobs
Brief	Manager/CEO summary from LLM or offl
Offline provider	Brain thinking without OpenAI/Anthro
Manager	Human who approves or rejects (you,

Sentinel Stacks ? Brain B1-B3 ? Beginner build report